Building a Responsible Bug Bounty Recon Workflow

Case Study: PayPal HackerOne Scope

March 23rd, 2026

Yuri Son

What is Bug Bounty

Bug bounty is:

- A program where companies invite security researchers
- To find and report security vulnerabilities
- In exchange for rewards

Instead of attacking systems illegally, researchers:

- Follow strict scope rules
- Report vulnerabilities responsibly
- Help improve security

It is ethical hacking under permission.





Project Goal

Objective:

For this project, I did NOT try to exploit anything.

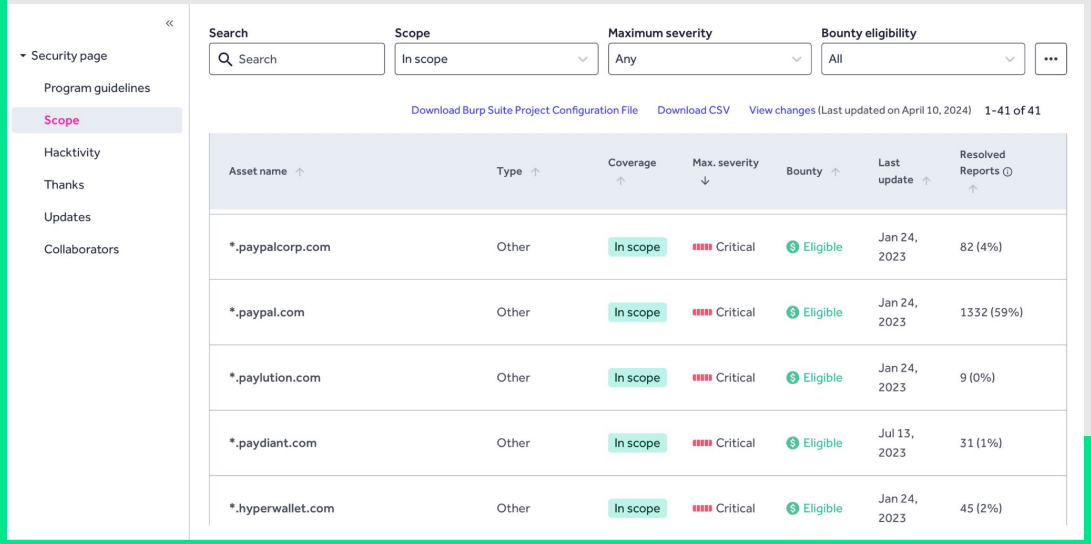
My Goal

- Understand how real bug bounty research works
- Build a reconnaissance workflow
- Follow ethical and scope boundaries
- Analyze potential attack surfaces responsibly

Step 1: Scope Validation

This means:
All subdomains of paypal.com are eligible.

Scope validation prevents legal and ethical issues.



Step 2: Subdomain Enumeration

Goal: Find all subdomains under paypal.com
Tool used: subfinder
subfinder-> finds valid subdomains for websites

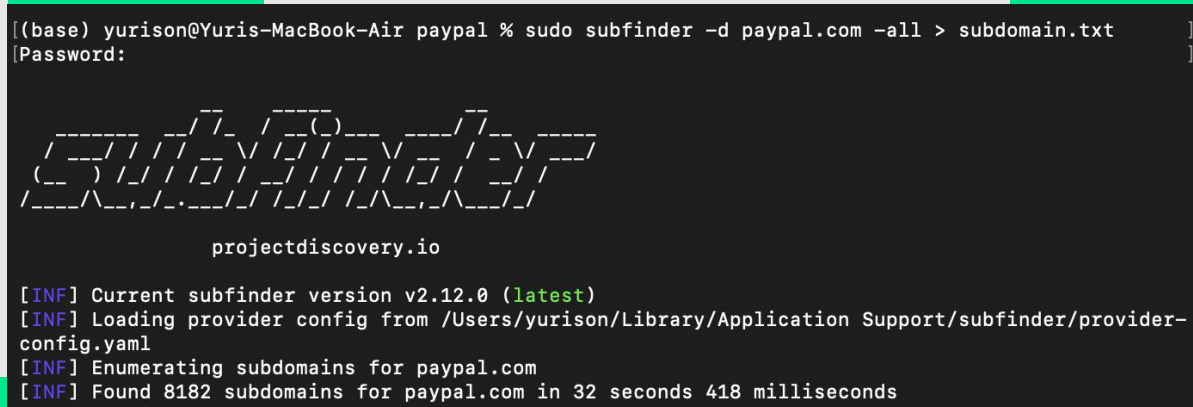
Result:

8,182 subdomains discovered

This process maps the attack surface.

But many subdomains are inactive or irrelevant.

Subdomain Enumeration:
Subdomain enumeration tools are security utilities used to discover valid subdomains (e.g., dev.example.com) associated with a main domain (e.g., example.com) It helps to expand the attack surface, identify forgotten, or forgotten, or ”shadow” infrastructure..



Step 3:
Live Host Detection

Goal: Find all subdomains under paypal.com

Tool used:

httpx-> finds lists of domains or subdomains to identify security misconfigurations

HTTP status codes:

- 200 → working
- 301 → redirect
- 404 → not found
- 500/502 → server error

```
(base) yurison@Yuris-MacBook-Air paypal % cat alive_subdomain.txt | httpx -sc > alive_domain_code
.txt

    __    __  __       _  __
   / /_  / /_/ /_____ | |/ /
  / __ \/ __/ __/ __ \|   /
 / / / / /_/ /_/ /_/ /   |
/_/ /_/\__/\__/ .___/_/|_|
             /_/

                projectdiscovery.io

[INF] Current httpx version v1.8.1 (latest)
[WRN] UI Dashboard is disabled, Use -dashboard option to enable
(base) yurison@Yuris-MacBook-Air paypal % cat alive_domain_code.txt
https://api.glb.paypal.com [421]
https://slc-a-origin-history.paypal.com [421]
https://origin-history.paypal.com [421]
https://phx-origin-history-2.paypal.com [421]
https://16695532.paypal.com [404]
https://0cd20b6fe61233e4a24bf70f30c9ba46.paypal.com [400]
https://accounts.hcaptcha.paypal.com [404]
https://apex.glb.paypal.com [421]
http://pns-int.paypal.com [301]
http://openbanking-uk.paypal.com [301]
http://tsp-int.stage.paypal.com [301]
http://commerce.sandbox.paypal.com [530]
https://adjvendor.paypal.com [200]
http://zootapi.paypal.com [530]
http://threeds-cb.stage.paypal.com [301]
http://api-m.glb.paypal.com [530]
http://dcg11-origin-history-2.paypal.com [530]
http://dcg11-origin-www-1.paypal.com [530]
http://developer.glb.paypal.com [530]
http://slc-origin-www.paypal.com [530]
http://dcg11-origin-mobile.paypal.com [530]
http://dcg11-origin-www.paypal.com [530]
http://www.networktoken.stage.paypal.com [301]
http://api.test71.stage.paypal.com [301]
http://slc-a-origin-history-2.paypal.com [530]
http://api.networktoken.stage.paypal.com [301]
http://threeds-discover.stage.paypal.com [301]
http://o365a.paypal.com [301]
http://poc-edge.paypal.com [301]
http://autodiscover.paypal.com [301]
http://svcs-silo.dcg11.paypal.com [530]
http://c6.glb.paypal.com [530]
https://api-3t-v2.sandbox.paypal.com [404]
https://api-3t.paypal.com [404]
https://api-3t.glb.paypal.com [404]
https://api-3t.sandbox.paypal.com [404]
https://api-3t.sandbox.glb.paypal.com [302]
http://dcg11-origin-mediaproxyweb.paypal.com [530]
http://dcg11-origin-www-2.paypal.com [530]
http://dcg11-origin-history.paypal.com [530]
http://dcg11-origin-mobileclient.paypal.com [530]
https://api-aa.paypal.com [400]
https://slc-b-origin-history.paypal.com [421]
```

Step 4: Web Crawling

Target: registration.paypal.com

Tool used:

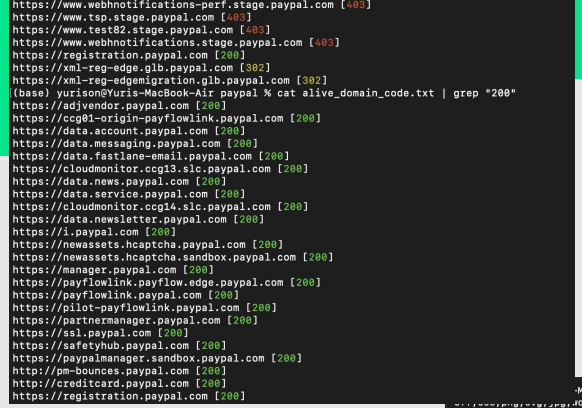
katana-> maps out the structure, endpoints, and resources of web applications

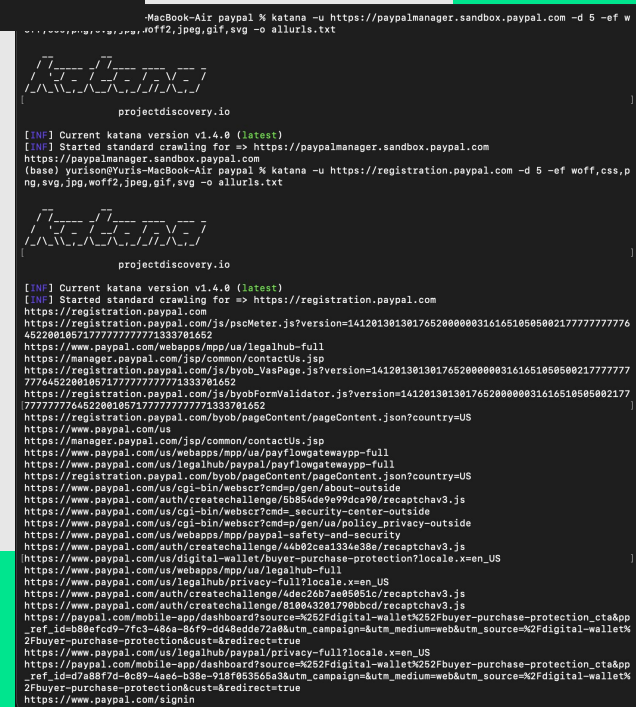
Result:

- 1,373 URLs discovered
- 608 URLs with parameters

Crawling helps identify:

- Hidden endpoints
- API routes
- Input parameters





Step 5: Parameter Analysis

I filtered for high-risk parameters such as:

- redirect=
- return=
- next=
- token=

These parameters are often linked to:

- Open redirect vulnerabilities
- Authentication flaws
- Logic errors

This step moves from “finding URLs” to “thinking about vulnerabilities.”



What I learned

- Most results are noise
- Scope validation is critical
- Ethical boundaries matter
- So many tools and resources are needed

THANK YOU!